ACME: Initial requirement analysis

Group 1: Felix Fehlauer, Jens Jonsson, Måns Lorentzen, Luca Manzari, Kotaro Seki

1 Scope and Objectives

1. Manage employee identities.
2. Secure communication between London and Stockholm offices.
3. Allow users outside the London and Stockholm offices to use a VPN to connect to the Stockholm or London offices. VPN users are only allowed access to certain less critical services.
4. Prevent DoS attacks from interrupting communication between offices.
5. Intrusion detection using LLMs in conjunction with traditional rule-based systems.
6. Logging of critical servers and traffic.
7. Secure file sharing and communication between employees.
8. Certificate-based authentication and identification; VPN users require additional 2FA.
9. Certificate revocation.
10. Secure WiFi and network authentication.
11. Automatic renewal of certificates for public-facing web servers.
12. Protect against DNS spoofing and hijacking.
13. Physical security and side-channel attacks are out of scope.

2 Preliminary Action Plan

The identities and accounts of employees will be managed using LDAP (1).

Secure communication between the London and Stockholm offices (2) will be implemented using a permanent VPN tunnel such as WireGuard or OpenVPN. Network segmentation with VLANs will ensure that only authorized traffic passes and that only less critical services are available to remote VPN users (3). Firewalling and routing will be handled by OpenWrt, VyOS, or OPNsense.

To reduce the impact of DoS attacks on office communication (4), VPN traffic between branches and ordinary internet traffic will be isolated as far as the available infrastructure allows.

An LLM-based system will be deployed to analyze logs on a log server such as Graylog (5,6), while a traditional IDS such as SNORT will monitor network traffic in real time (5). In particular, logs from an additionally secured web server and from a honeypot will be collected.

Employee certificates will be issued and revoked using a CA server such as Dogtag (8,9).

Secure file sharing between employees will be facilitated using an OpenCloud or Nextcloud server (7).

Authentication will be handled through Keycloak (8), which enforces certificate-based login and 2FA for VPN users when certificates are not used (3,8).

WiFi and network authentication (10) will use WPA3-Enterprise with EAP-TLS and FreeRADIUS for authentication. The access points will run OpenWrt to enforce secure network policies.

Public company web servers will be located in a DMZ and secured with Let's Encrypt certificates (11).

To protect against common DNS attacks such as spoofing and hijacking, a DNS server implementing DNSSEC will be deployed (12).

3 Finalized Requirement Analysis & Design

This section presents the finalized requirement analysis and the resulting network design for ACME. It includes an overview of the topology, the deployed services, and the main strengths of the proposed solution.

3.1 Network Topology Overview

The proposed network solution is divided into two main sections: the London network and the Stockholm network. The Stockholm network hosts the core services of ACME, while the London network primarily provides access to services hosted in Stockholm. The connection between the offices is established using a permanent site-to-site VPN tunnel. The topology is shown in Figure 1. Even within the internal network, traffic is encrypted where appropriate and individual services require authentication.

3.1.1 Routers

The routers will be configured to run OpenWrt, with the following services:

- **Routing**.
- **Firewall**.
- **SNORT** for intrusion detection.
  By placing SNORT directly on the router, traffic can be monitored centrally for signs of intrusion without requiring a separate network tap or port mirroring setup.
- **DHCP**.
- **WiFi access point**.
  WiFi authentication will be performed using WPA3-Enterprise and EAP-TLS, preferably in 192-bit mode where supported. WPA3-Enterprise is preferable to WPA2 because it offers stronger cryptography as well as support for protected management frames and operating channel validation.
- **WireGuard VPN server**.
  WireGuard was chosen because it is modern, efficient, and comparatively easy to deploy for both site-to-site and remote-access VPN use cases.

OpenWrt was chosen as a single solution due to limitations in the number of available ports and the available WiFi hardware.

3.1.2 Stockholm Network

The Stockholm network is split into three VLANs:

- **VPN:** This VLAN is where employees connecting remotely through the VPN will be placed. It also hosts services that both VPN users and on-site employees should have access to:
  - **FreeIPA**.
    FreeIPA is a complete identity management system. It provides an LDAP server, a PKI certificate authority using DogTag, and authoritative and recursive DNS services, including DNSSEC via BIND.

    FreeIPA therefore enables centralized user management as well as certificate issuance and revocation. By signing DNS records and validating responses, it also helps protect against attacks such as DNS spoofing, hijacking, and cache poisoning.
  - **Apache Web Server** (VPN users allowed).
    This internal web server hosts non-critical information intended to be reachable by both on-site users and remote employees.
  - **Keycloak**.
    Keycloak provides centralized authentication for applications and services. Combined with FreeIPA as the user directory, it enables Single Sign-On (SSO). It also supports 2FA when users authenticate to web services with username and password instead of a certificate stored on their corporate laptop. This second factor can be provided either by a TOTP app on the employee's smartphone or by a YubiKey. The use of a hardware token further improves resistance to phishing.
  - **Nextcloud**.
    Nextcloud is a collaboration platform that supports, among other things, file sharing and

secure communication between employees. Remote users access it through the WireGuard VPN.
  - **FreeRADIUS**.
    FreeRADIUS is used to authenticate users to the network through certificate-based EAP-TLS.
  - **Honeypot**.
    A honeypot is deployed as bait and as an additional source of telemetry for intrusion detection.

  All authenticated users have access to this VLAN. The working assumption is that an authenticated user is a legitimate employee, and therefore Keycloak and FreeRADIUS are not placed on a separate management VLAN.
- **LOCAL:** This VLAN is where on-site employees connect. It also hosts services that should only be accessible to on-site employees, such as:
  - **Grafana Loki**.
    A log server that collects logs using Promtail or Alloy.
  - **Apache Web Server** (VPN users not allowed).
  - **LLM log analyzer**.
    An LLM-based analyzer processes collected logs and looks for signs of intrusion. This complements signature-based detection by helping identify suspicious patterns, attacker behavior, and possible attack methodology. The analyzer runs periodically and stores its results in Grafana Loki.
- **DMZ:** The DMZ contains publicly accessible services, such as the public-facing web server. This server is secured with a Let's Encrypt certificate to enable HTTPS. Port forwarding is used to make it reachable from the internet. To allow access via a public URL, a dynamic DNS service such as FreeDNS is used.

The IP configuration of each VLAN can be seen in Figure 1. Additionally, the VPN VLAN is not allowed to initiate connections to the LOCAL VLAN.

3.2 DoS Mitigation

The original plan for DoS mitigation proved infeasible because only a single uplink was available. The revised approach is therefore to mitigate DoS at the network and application layers, since the physical and data-link layers are outside the scope of this project.

3.3 London Network

The London network is intentionally minimalist. All core services are hosted in Stockholm, which brings both benefits and drawbacks. One benefit is administrative simplicity: for example, if a Stockholm administrator deletes a user from the FreeIPA server, there is no need to synchronize that change to London. Another benefit is lower cost, since fewer services must be duplicated.

4 Implementation: A virtual network

The following section describes the Stockholm network as implemented in a largely virtualized environment, with the exception of the physical OpenWrt router. This allowed all services to be hosted on a single laptop running Ubuntu 24.04 LTS. The services and machines described below were therefore implemented as virtual machines.

4.1 Management of employee identities and authentication to services

To manage user identities, FreeIPA was implemented. This allows the creation of users, the issuance of certificates for users and servers, and the revocation of those certificates. To reduce the risk of data exfiltration and trivial enumeration, anonymous access to the LDAP directory is denied.

In addition to user management, ACME required certificate-based authentication for services running in the network. This was implemented using Keycloak. Keycloak connects to FreeIPA over LDAP and uses it as its user database. When a user attempts to access a protected service, the user is redirected to the Keycloak authentication page. The user then has two options: authenticate using an X.509 certificate signed by the FreeIPA CA, or sign in using username and password together with 2-factor authentication.

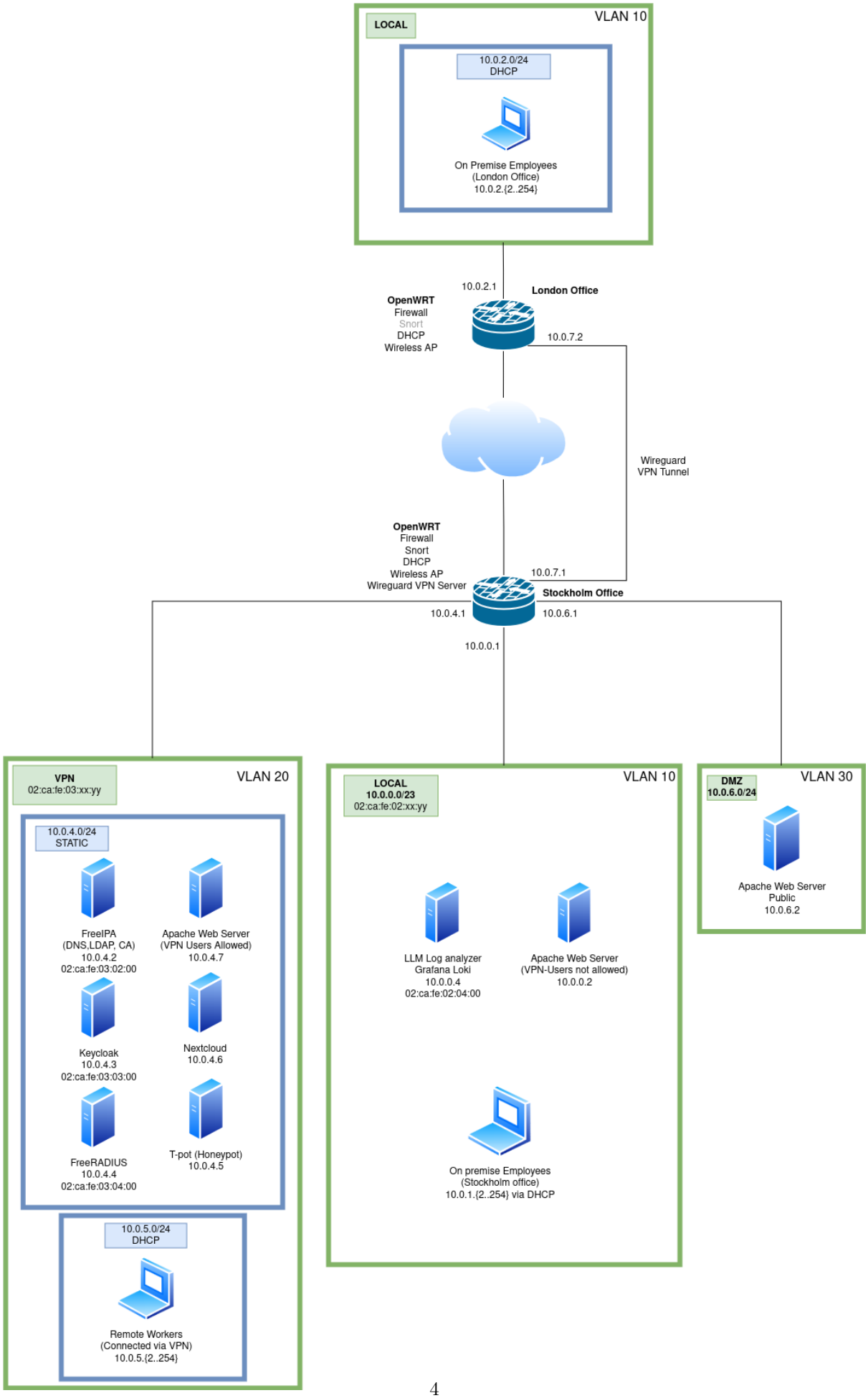

Figure 1: Suggested network topology for ACME's network.

When certificate-based login is used, Keycloak verifies the certificate and checks whether it has been revoked. The 2-factor authentication setup is managed centrally through FreeIPA. Due to time constraints, however, a hardware-token solution using YubiKeys was not fully implemented.

Private keys are generated on the employee's laptop using OpenSSL, and certificates are issued either manually through the FreeIPA interface or through the *ipa* client on the employee's laptop.

4.2 Secure communication

ACME required that its sensitive web server not be accessible to users who are off-site. In the implementation, this was enforced through firewall rules. The OpenWrt firewall is configured so that machines on VLAN 20 (VPN) are not allowed to *initiate* connections to VLAN 10 (LOCAL). Some traffic still has to pass between the VLANs because of authentication through Keycloak and the collection of telemetry from the honeypot. VLAN 20 is therefore allowed to respond to established connections but not to start new ones toward LOCAL services.

Access attempts to the critical web server are monitored using Promtail installed on the server. Promtail forwards access logs to Grafana Loki, where they can be reviewed in Grafana. Network traffic is additionally monitored by SNORT running on the OpenWrt router.

To allow communication between the two branches, a WireGuard tunnel is established between the routers in Stockholm and London. The router in Stockholm also runs a WireGuard VPN server for remote users, assigning them addresses in the VPN network. VPN credentials are distributed by IT in the form of a self-contained configuration file that works across platforms.
A Nextcloud server is provided for secure file exchange and chat, and access to it is also integrated with Keycloak.

4.3 Confidentiality and privacy

Confidentiality is ensured through the use of TLS for service communication. All servers use certificates signed by the FreeIPA CA, enabling HTTPS, keeping traffic encrypted, and establishing trust. TLS is also used for communication between LDAP and Keycloak. WireGuard ensures that traffic between the offices and to remote workers is encrypted in transit. Observers on untrusted networks would be able to see that users connect to ACME, but not the content of the communication.

The critical web server was also hardened in case it were to be compromised. Local firewall rules restrict which outgoing connections it may *initiate*: only approved IP addresses are permitted, namely the log server to push logs, the Keycloak server for authentication-related communication, and the DNS server. As a defense-in-depth measure, incoming connections from outside the intended local network paths are denied.

Logs sent to Grafana Loki are also treated as confidential and are transmitted over HTTPS. Furthermore, to prevent unauthorized clients from pushing or reading logs, the Loki server requires client authentication using certificates.

4.4 Secure Wireless Access

Wireless access is provided by the OpenWrt router's access point. Authentication is performed using WPA3-Enterprise with EAP-TLS and FreeRADIUS as the authentication server. In addition, RADIUS traffic is protected through RadSec, which strengthens the transport security of authentication traffic. The FreeRADIUS server allows only TLS 1.3 for improved security.

Due to an open issue in NetworkManager, automatic support for the preferred WPA3-Enterprise configuration is currently limited. As a result, WiFi access on Linux currently requires some manual configuration. This is an implementation limitation rather than a design limitation, and there is ongoing upstream work on the issue.

4.5 Other security

To mitigate DNS attacks such as spoofing, the FreeIPA DNS server signs all hosted zones with DNSSEC and also supports validation of signed recursive responses. This ensures that the authenticity and integrity of DNS responses can be verified.

A honeypot running OpenCanary v0.9 is placed in VLAN 20. The initial plan to use T-Pot was abandoned because of hardware constraints. The honeypot is deployed in VLAN 20 to monitor attackers who may already have reached the internal network. Placing it in the DMZ would have made it too

broadly exposed, reducing its usefulness as both an intrusion-detection aid and a strategic distraction from more critical assets.

Appendices

A Changes based on peer feedback

The following changes were made after receiving peer reviews.

- The network topology diagram now includes network segments and VLAN IDs.
- An explanation was added for why no service is hosted in the London office.
- An explanation was added for how remote VPN authentication works and how VPN users are placed in the network, and therefore how their access is limited.
- The issue of secure communication was addressed both for remote access and for communication between employees.
- More specific reasons were added for the technological choices made.
- The honeypot was moved to the internal network.
- The meaning of an authenticated user was clarified.

B Technical Details

Internally, certificates use 4096-bit RSA to maximize compatibility while maintaining a high security margin.

B.1 FreeRADIUS and WiFi

- Due to limitations of OpenWrt, WiFi authentication requests are proxied via a specially patched *radsecproxy* running locally on OpenWrt, which then establishes a RadSec (RADIUS over TLS) connection.
- Message-Authenticator is required in all Access-Request packets.
- Only EAP-TLS authentication is allowed.
- To reduce leakage of presence information, pseudonymous certificates are allowed for access.
- The WiFi networks use WPA3-Enterprise with SHA256, GCMP-256 for pairwise and group ciphers, and BIP-GMAC-128 for group management. Protected management frames (PMF) and operating channel validation (OCV) are enforced to mitigate common WiFi attacks.
- WPA3-Enterprise 192-bit mode could not yet be enabled for all devices, because while *wpa_supplicant* on Linux supports it, the available Android devices do not. The design nevertheless supports a future rollout once the Android devices are updated.
- Additionally, the server certificate common name (domain) is checked as an extra validation step.
- To support the RadSec client, a service account without a password and with */sbin/nologin* is used for additional hardening.

B.2 LLM

The network includes an LLM that analyzes logs for signs of intrusion. A Python script queries the Loki database for the last five minutes of logs, feeds them to the LLM in chunks, and writes the LLM's responses to a log file. Promtail then collects those logs and pushes them back to Loki.

The model used is LLaMA 3.2–3B, run through a Snap package of Ollama. The script sends log lines to the model via the Ollama HTTP API using the Ollama Python package. This traffic remains on localhost and therefore does not require separate transport encryption.

B.3 Keycloak

- Access to Grafana is implemented using OpenID Connect (OIDC) over OAuth 2.0. Grafana's generic configuration is set up so that it works as a client of the Keycloak OIDC provider. Client authentication is handled using a secret generated by Keycloak.

- Access to the LDAP directory is performed via LDAPS using a dedicated Keycloak service account, in accordance with the principle of least privilege.
- Access to the internal web servers is also protected using OpenID Connect.
- Revoked certificates are checked against FreeIPA using the Online Certificate Status Protocol (OCSP).

B.4 Log collecting

Log collection is performed using Promtail. Although Promtail is now deprecated, it was still used because it was easy to set up and sufficient for the requirements of this prototype. In a full production setting, Grafana Alloy should be considered instead. Logs from the honeypot and the router are collected using *scp* as a *cron job* that copies them to the Grafana Loki server every five minutes. Since Promtail would otherwise need to *initiate* a connection to the Grafana Loki server across a path restricted by firewall rules, *scp* is used from the Loki side to pull the logs instead.

B.5 Critical web server

Below, the local firewall configuration can be seen:

```
Default: deny (incoming), deny (outgoing), disabled (routed)
New profiles: skip
To                         Action      From
--                         ------      ----
Anywhere                   ALLOW IN    10.0.0.0/23

10.0.4.2                   ALLOW OUT   Anywhere
10.0.4.3                   ALLOW OUT   Anywhere
10.0.0.4                   ALLOW OUT   Anywhere
```

B.6 Public web server

The public web server uses a certificate from Let's Encrypt.

B.7 A note on hardware

It is important to note that the demonstrated Stockholm environment was implemented as a proof of concept on highly constrained hardware. With the exception of the physical OpenWrt router, the Stockholm-side infrastructure was effectively virtualized on a single laptop equipped with two Ethernet interfaces. One interface was used to carry multiple trunked VLANs over a single 1 Gbit/s Ethernet connection to the OpenWrt router. The second laptop interface was used separately for management access to OpenWrt, with appropriately defined routes. In addition, a third LAN port on the OpenWrt device was kept available as a fallback management or recovery path in case the primary setup failed during development or demonstration. The WAN port of the router was assigned a public IP address.

This setup made it possible to demonstrate routing, VLAN segmentation, VPN connectivity, authentication services, logging, and the rest of the Stockholm-side services using very limited physical infrastructure. From a pedagogical and experimental perspective, this was beneficial because it enabled rapid iteration and simplified deployment. At the same time, this hardware arrangement was chosen for demonstration purposes only and should not be interpreted as a production-ready deployment model.

Similarly, the SNORT instance was run on a low-end Asus device with a limited set of demonstration rules. While this was sufficient to illustrate the intended intrusion-detection workflow and its integration into the broader security design, it is not representative of how such a service should be deployed in an enterprise environment. In a real-world setting, intrusion detection and traffic inspection should be placed on appropriately dimensioned dedicated hardware to ensure both performance and reliability under sustained load.

Overall, the implementation should therefore be understood as a functional proof of concept rather than as a recommendation for operational hardware sizing. A production deployment would require enterprise-grade networking equipment, more capable compute resources, and dedicated systems for security-critical services. Nevertheless, the fact that the solution could be demonstrated successfully on such modest hardware highlights the portability of the design and the robustness of the overall architecture.

5 Final remarks

5.1 As presenting team

The presentation went well, and we are confident that we demonstrated a solid solution. Most demonstrations worked without major problems, although there was an unfortunate delay when presenting DNSSEC. Providing a NetworkManager configuration is currently limited by the fact that the chosen Android-compatible WiFi configuration is not yet properly supported in NetworkManager. There is ongoing work to obtain a working patch.

The xPKI requirement was not fully met due to time constraints.

5.2 As opposing team

The presentation was strong overall, and the use-case videos were effective. However, the decision to place the RADIUS server in the DMZ was questionable and was not convincingly justified. The practical demonstration also suffered from several issues. An expired Kerberos ticket during certificate creation could not be resolved, and the understanding of secure file sharing in Nextcloud appeared limited.

ACME Scandinavia: Employee Guide to Secure Network Access

Welcome to the ACME secure network. This guide explains how to connect to company resources, whether you are working from the Stockholm or London office, from home, or while traveling. Just follow the steps below.

How Authentication Works at ACME

ACME uses personal digital certificates as the primary way to verify your identity. Think of your certificate as a digital ID badge. Once installed on your device, it proves who you are without requiring a password every time.

If you are using a device that does not have your certificate installed, such as a personal computer, you can still sign in using your username, password, and a one-time code from an authenticator app. This two-factor method is a backup, not the default.

1. Your Personal Certificate

Every ACME employee receives a personal certificate file (`.p12` format) together with a password to unlock it. Your certificate is a personal credential and must not be shared.

▲ Certificate private keys should never be transferred via insecure channels such as email.

On your company laptop

Linux

The IT department will preconfigure your desktop. This includes configuring Firefox to trust the Certificate Authority (CA) and to automatically present your user certificate when accessing internal services.

macOS

1. Double-click the `.p12` file. It will open in Keychain Access.
2. Enter the password when prompted.
3. The certificate is now stored in your keychain.

Once installed at the operating-system level, Chrome, Safari, and Edge will detect and use your certificate automatically. No further steps are required for these browsers.

Firefox users only (additional step): If you are using a browser other than Firefox, you may skip this step. Firefox uses its own certificate store and will not automatically detect certificates installed at the OS level.

1. Go to `Settings > Privacy & Security > scroll to Certificates > View Certificates`.
2. Under "Your Certificates," click `Import` and select your `.p12` file.
3. Enter the password and click `OK`.

On your phone

Android

1. Transfer the CA certificate and your `.p12` file to your phone using a secure method.
2. Install the CA certificate twice: once as a "Wi-Fi Certificate" for office WiFi and once as an "App/VPN Certificate" for browser trust.
3. Transfer and install your `.p12` user certificate. Note: certificate-based website login on Android works well for the Keycloak portal, but is currently not working for the FreeIPA interface itself.

▲ If your device is lost or stolen, contact IT immediately so that your certificate can be revoked.

2. Connecting from the Office (Wi-Fi)

Both the Stockholm and London offices provide a secure Wi-Fi network. Once your personal certificate is installed (see Section 1), simply select the ACME corporate network in your Wi-Fi settings. Your certificate will verify your identity automatically, so no Wi-Fi password is required.

3. Working Remotely (VPN)

When you are outside the office, you must connect through the company VPN to access internal resources. ACME uses WireGuard, a fast and reliable VPN solution.

Step 1: Obtain your VPN configuration

For macOS and Linux, download WireGuard from `http://wireguard.com/install` or install it using your package manager. For Android, install the WireGuard app from the Google Play Store.

Step 2: Import your VPN configuration (one-time)

The IT department will generate your WireGuard credentials and provide you with a configuration file named `wg-stockholm.conf`. This file contains everything needed to securely connect to the ACME network.

- **Desktop:** Open WireGuard > "Import tunnel(s) from file" > select the `.conf` file.
- **Mobile:** Open WireGuard > tap the `+` button > Import from file > select the `.conf` file.

Step 3: Connect

Toggle the ACME tunnel ON. When the status shows active, you are securely connected and can access company resources as if you were in the office.

▲ VPN users can access most services, but certain sensitive resources are only available from within the Stockholm or London office.

4. Two-Factor Authentication (2FA): Backup Access

If you need to sign in from a device without your certificate, for example a personal laptop at home, ACME requires two-factor authentication. We use Ente Auth, an authenticator app available on the Google Play Store.

Setting up Ente Auth (one-time)

On your Android phone, install Ente Auth from the Google Play Store.

1. From a device where you are already signed in, visit the Keycloak portal (see Section 5).
2. Go to your account security settings and select "Set up authenticator application."
3. A QR code will appear. Open Ente Auth on your phone and scan it.
4. Enter the 6-digit code shown in Ente Auth to confirm setup.

Using 2FA to sign in

1. Enter your username and password on the login page.
2. Open Ente Auth. It will display a 6-digit code that refreshes every 30 seconds.
3. Enter the code when prompted. You are now signed in.

5. ACME Applications: Where to Find Everything

Once connected, whether from the office or through the VPN, you can access the following services in your browser. All internal services support Single Sign-On (SSO) through Keycloak, so in most cases you only need to authenticate once.

Service	URL	Who can access
Keycloak Portal (SSO)	`https://keycloak.acme.internal`	All employees
Nextcloud (file sharing)	`https://10.0.4.6`	All employees
Internal Web Server	`https://internal.acme.internal`	All employees
Critical Web Server	`https://critical.acme.internal`	On-site only
Public Website	`https://bnssacme.mooo.com`	Anyone

We recommend bookmarking the Keycloak portal as your starting point. Because Keycloak provides Single Sign-On, logging in there will usually give you access to the other internal services without needing to authenticate again.

For any issues, please contact the IT department.